

Análisis de la entropía y el cumplimiento de Ley de Benford en contraseñas del dataset RockYou.txt mediante la tokenización de sus subcadenas

Anthony Flores Rojas¹, Andrey González Bastos², Randal Picado Bermúdez³, Leonardo Vega Aragón⁴

anthony.flores@ucr.ac.cr, andrey.gonzalezbastos@ucr.ac.cr,
randal.picadobermudez@ucr.ac.cr, leonardo.vegaaragon@ucr.ac.cr

RESUMEN

Las contraseñas constituyen el principal mecanismo de autenticación en sistemas digitales; sin embargo, las mismas suelen contener patrones y estructuras predecibles por influencia de los usuarios, estos patrones pueden reducir su seguridad. Esta investigación tuvo como objetivo determinar en qué medida la composición de caracteres, la longitud y la distribución de dígitos de las contraseñas del dataset RockYou influyen en su entropía y evidencian comportamientos no aleatorios.

Se analizó el dataset RockYou mediante tokenización CL100K y el cálculo de una representación numérica asociada a cada contraseña. Posteriormente, se evaluó el ajuste a la Ley de Benford mediante la prueba de Kolmogorov-Smirnov (KS). Sin tokenizar las contraseñas se calculó la entropía de Shannon y se aplicó la prueba de Kruskal-Wallis para comparar niveles de entropía según el tipo de máscara (estructura interna de la misma) y la longitud de las contraseñas. Además se calculó la probabilidad de transición entre caracteres.

La prueba KS mostró que las posiciones 1 y 2 se desvían significativamente de la distribución teórica de Benford ($D = 0.0985$ y $D = 0.0108$), a partir de la posición 3 no se rechazó el ajuste a dicha ley ($D = 0.0003$). Asimismo, la prueba de Kruskal-Wallis confirmó diferencias significativas en la entropía según el tipo de máscara ($H = 4\,366\,419.48$, $p \approx 0$) y la longitud de la contraseña ($H = 14\,084\,456.87$, $p \approx 0$). Por último, la matriz de transición reveló que las transiciones se concentran entre letras en minúsculas.

Los resultados indican que las contraseñas del dataset estudiado poseen una estructura estadística identificable y parcialmente predecible. La composición de caracteres, la longitud y los patrones de transición influyen significativamente en la entropía observada, evidenciando que los usuarios no seleccionan contraseñas de forma completamente aleatoria.

PALABRAS CLAVE

Tokens, Ciberseguridad, Máscaras, Distribuciones, Kolmogorov.

¹Estudiante de Ciencias Actuariales, UCR.

²Estudiante de Ciencias Actuariales, UCR.

³Estudiante de Ciencias Actuariales y Matemática UCR.

⁴Estudiante de Matemática y Ciencias Actuariales, UCR.

INTRODUCCIÓN

El desarrollo de la tecnología y las bases de datos electrónicas han llegado a cambiar el juego de la información. Cada día se les confían más datos personales y sensibles a distintos softwares de distintas compañías, aplicaciones bancarias que se utilizan para realizar transacciones, redes sociales, chats empresariales y demás herramientas de este tipo.

En la investigación, se usará el sonado caso de la filtración de RockYou, un hackeo que se realizó en el año 2009, del cual se obtuvo un dataset bastante robusto de contraseñas para poder realizar análisis y estudios posteriores. Teniendo en cuenta todo lo anterior, resulta fundamental y oportuno, estudiar a detalle la composición de las contraseñas y como los usuarios dejan patrones en ellas. Saber la naturaleza de las contraseñas resulta beneficioso para así poder detectar anomalías en bases de datos de contraseñas, así como posibles ataques a los sistemas informáticos de instituciones.

En específico, el tema de la presente investigación se trata de indagar sobre la aleatoriedad de las contraseñas, con la siguiente pregunta de investigación: ¿En qué medida los patrones estructurales de las contraseñas del dataset RockYou2009 —su composición de caracteres, longitud y distribución de dígitos— determinan su nivel de entropía y evidencian que los usuarios no eligen contraseñas de forma aleatoria?, se pretende descubrir si los usuarios toman en cuenta la aleatoriedad o solo se basan en patrones muy conocidos y fáciles de recordar, vulnerando así su seguridad.

Para robustecer el análisis y darle un mayor rigor estadístico, la investigación incorpora herramientas que van más allá de la estadística descriptiva convencional. Por un lado, se aplicará la Ley de Benford y la tokenización de las subcadenas de las contraseñas. Por otro lado, se recurrirá a pruebas de bondad de ajuste como la prueba de Kolmogorov-Smirnov y la prueba de Kruskal-Wallis, las cuales permitirán evaluar si la distribución de las contraseñas sigue o se aleja significativamente de lo que cabría esperar bajo un modelo de aleatoriedad pura, todo esto será explicado con más detalle en la metodología.

METODOLOGÍA

Los datos se filtraron en diciembre de 2009 debido a una vulnerabilidad de la seguridad de las bases de datos de la compañía RockYou, esta misma permitió que un hacker recolectara la creación de contraseñas de finales de la década de 2000. El origen de los mismos es California, Estados Unidos, pero el impacto fue global al afectar a millones de usuarios internacionales de redes sociales como Facebook y MySpace que utilizaban widgets y aplicaciones sociales dentro de estas propias redes sociales.

Consiste en 32,603,388 registros de usuarios que fueron extraídos directamente de la base de datos de RockYou tras el hackeo. De estos se usaron dos listas, tanto la más común para ciberseguridad (rockyou.txt), que contiene 14,344,386 contraseñas únicas tras eliminar duplicados, y la lista completa (rockyouwithcounts.txt).

Sea c una contraseña del conjunto de datos $\mathcal{C}$. El tokenizador CL100K la transforma en un vector de embeddings:

$$\text{CL100K}(c) = \mathbf{v}_c = (v_1, v_2, \dots, v_d) \in \mathbb{R}^d, \quad (1)$$

donde d es la dimensión del embedding.
Se elige la norma de valor absoluto del vector

$$\|\mathbf{v}_c\|_1 = \sum_{i=1}^d |v_i| \in \mathbb{R}_{\geq 0}. \quad (2)$$

Esta norma fue elegida simplemente por su interpretación directa como la suma total de las magnitudes de las componentes del vector de tokenización, lo que permite extraer la distribución de dígitos en cada posición del número resultante.

Prueba de Kolmogorov-Smirnov contra la distribución de Benford

La Ley de Benford establece que en conjuntos de datos numéricos de origen “natural”, el dígito d ocupa la primera posición con una frecuencia predecible (Caputi Zunini, 2019). Si los dígitos presentes en contraseñas reales se desvían de esa distribución, existe evidencia de que los usuarios eligen números con sesgos sistemáticos, lo que implica predecibilidad y, en consecuencia, vulnerabilidad. Se elige la prueba KS (y no una chi-cuadrado) porque compara funciones de distribución acumulada completas sin requerir agrupar celdas; con muestras en el orden de millones, la chi-cuadrado infla el estadístico por el tamaño de n sin aportar información sobre la forma de la desviación (Chandola, Banerjee, & Kumar, 2009; Chandy, Schifano, Yan, & Zhang, 2025).

Estadístico KS

Sea $F_n(x)$ la función de distribución acumulada empírica de los dígitos en la posición p y $F_0(x)$ la CDF teórica de Benford. El estadístico Kolmogorov-Smirnov es

$$D_n = \sup_x |F_n(x) - F_0(x)| \quad (3)$$

Se rechaza H_0 (los dígitos siguen Benford) cuando $D_n > D_\alpha$. Dado que $n \sim 10^6$, el umbral D_α es extremadamente pequeño, por lo que se complementa el resultado con la desviación absoluta media (MAD)

$$\text{MAD} = \frac{1}{|\mathcal{D}|} \sum_{d \in \mathcal{D}} |\mathbb{P}_{\text{emp}}(d) - \mathbb{P}_{\text{Benford}}(d)| \quad (4)$$

donde $\mathcal{D}$ es el conjunto de dígitos válidos para la posición dada. Los umbrales de conformidad son $\text{MAD} < 0,006$ (muy cercana), $0,006-0,012$ (aceptable), $0,012-0,015$ (marginal) y $> 0,015$ (no conformidad) (Negrini, 2012).

Distribución teórica de Benford generalizada

Sea $D_n \in \{1, \dots, 9\}$ el dígito en la posición n -ésima, entonces la PDF de Benford para $n = 1$ es $\mathbb{P}(\{D_1 = d\}) = \log_{10}(1 + \frac{1}{d})$. Para posiciones $n \geq 2$, la fórmula generalizada integra sobre todos los prefijos de longitud $n - 1$, siendo esta

$$\mathbb{P}(\{D_n = d\}) = \sum_{k=10^{n-2}}^{10^{n-1}-1} \log_{10} \left(1 + \frac{1}{10k+d} \right), \quad d \in \{0, 1, \dots, 9\} \quad (5)$$

Análisis de distribución de máscaras de contraseña

Las contraseñas humanas no son cadenas aleatorias, los usuarios exhiben patrones estructurales sistemáticos al elegirlos. Para capturar esa estructura sin depender del contenido semántico de cada contraseña, se utiliza una representación de máscara, que abstrae cada carácter a su tipo. Formalmente, dado el alfabeto de tipos $\Sigma = \{L, U, D, S\}$ (minúsculas, mayúsculas, dígitos, caracteres especiales), la máscara de una contraseña $P = c_1 c_2 \dots c_n$ es

$$M(P) = \tau(c_1) \tau(c_2) \dots \tau(c_n), \quad \tau(c) = \begin{cases} L & c \in \mathcal{L} \\ U & c \in \mathcal{U} \\ D & c \in \mathcal{D} \\ S & c \in \mathcal{S} \end{cases} \quad (6)$$

Para reducir el espacio de máscaras sin perder información sobre la composición, se aplica una codificación de longitud de racha (*run-length encoding*) sobre $M(P)$. Sea $M(P) = t_1^{r_1} t_2^{r_2} \dots t_k^{r_k}$ la descomposición en rachas consecutivas del mismo tipo, entonces el patrón comprimido es

$$R(P) = t_1 r_1 \ t_2 r_2 \ \dots \ t_k r_k \quad (7)$$

Por ejemplo, la máscara LLLLLLDD se comprime a L6D2. Esta representación agrupa contraseñas con la misma composición por bloques, lo que facilita el análisis de patrones frecuentes en el dataset. La distribución de patrones comprimidos se analiza por frecuencia absoluta f_j y proporción relativa $\hat{p}_j = f_j/N$, donde N es el total de contraseñas.

Entropía de Shannon

Sea P una contraseña y sea p_t la proporción del tipo $t \in \Sigma$ en P . La entropía de Shannon de P es

$$H_S(P) = - \sum_{t \in \Sigma} p_t \log_2 p_t \quad (8)$$

Prueba de Kruskal-Wallis sobre entropías por grupo

Se busca determinar si la estructura de la máscara (longitud y tipo dominante de caracteres) discrimina el nivel de entropía. Se elige Kruskal-Wallis (KW) en lugar de ANOVA de un factor porque

[noitemsep]

- Las distribuciones de entropía por grupo no son normales (asimétricas, con colas largas), como se verifica en el análisis descriptivo.

- KW es una prueba no paramétrica de rangos que no asume homocedasticidad ni normalidad dentro de los grupos.

Entropía de Shannon de una máscara

La entropía media de la máscara m se define como en la ecuación (8), donde $\Sigma = \{L, U, D, S\}$ es el alfabeto de tipos de carácter (minúsculas, mayúsculas, dígitos, símbolos) y p_c es la proporción del tipo c en m .

Estadístico de Kruskal-Wallis

Dadas k muestras independientes de tamaños $n_1, \dots, n_k$ con $N = \sum_{i=1}^k n_i$ observaciones totales, el estadístico es

$$H = \frac{12}{N(N+1)} \sum_{i=1}^k \frac{R_i^2}{n_i} - 3(N+1) \quad (9)$$

donde R_i es la suma de rangos del grupo i sobre el ranking global. Bajo H_0 (todas las distribuciones son iguales), $H \sim \chi_{k-1}^2$ para muestras grandes.

Agrupaciones evaluadas

Se aplica KW bajo tres criterios de agrupación
[noitemsep]

1. Longitud de máscara: grupos $g \in \{1, 2, \dots, L_{\text{máx}}\}$ donde $L_{\text{máx}}$ es la longitud máxima observada.
2. Tipo dominante: Solo L, Solo D, Solo U, Solo S, Mixta.
3. Rango de entropía: bajo ($H < 2,4464$, por debajo del percentil 25), medio ($2,4464 \leq H < 2,9477$, entre los percentiles 25 y 75) y alto ($H \geq 2,9477$, por encima del percentil 75). Este agrupamiento es descriptivo, no inferencial, pues la variable de agrupación coincide con la variable de respuesta.

Probabilidad de transición

Sea x el carácter de una posición cualquiera n y sea y otro carácter en la posición $n+1$ de la contraseña, la probabilidad de transición $\mathbb{P}(\{x, y\})$ viene dada por las k apariciones de la transición $\{x, y\}$ en el dataset y L el total de transiciones que contienen las contraseñas en total, de forma que

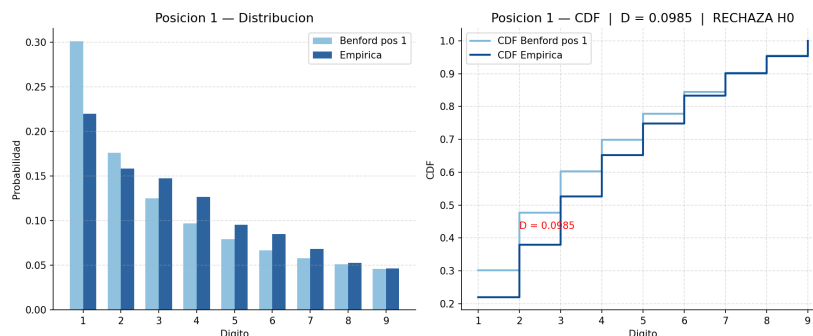
$$\mathbb{P}(\{x, y\}) = \frac{k}{L} \quad (10)$$

RESULTADOS

Los primeros resultados se obtuvieron mediante el uso del test Kolmogórov-Smirnov (KS). De esta manera, se evaluó si la distribución empírica de los dígitos en la n -ésima posición de las contraseñas tokenizadas se ajusta a la Ley de Benford. En el siguiente gráfico se muestran los resultados del análisis en la posición 1.

Figura 1

KS y Benford para posición 1 con contraseñas tokenizadas



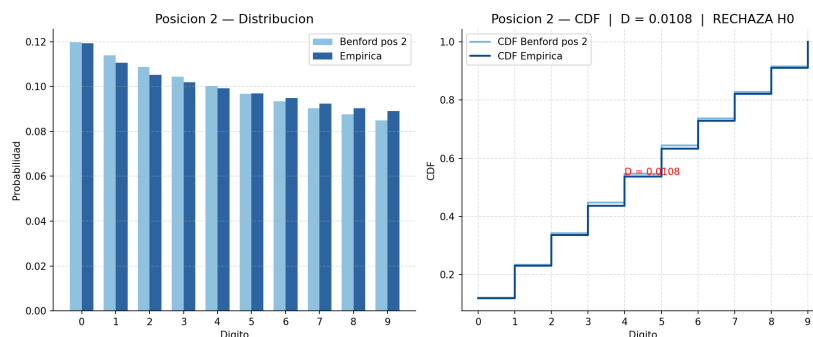
Nota. Pruebas KS aplicada para rechazar hipótesis nula en la posición 1.

Esto implica que las contraseñas no son completamente aleatorias en su primera posición: siguen un patrón parcialmente compatible con Benford, pero no con la rigurosidad formal requerida por el test. Este resultado se apoya en la literatura de Caputi (2019) sobre la Ley de Benford y en Chandy et al. (2025) sobre el test KS, y motiva la exploración de las posiciones subsiguientes para determinar si el ajuste mejora a medida que avanza la posición.

En sintonía con lo anterior, el segundo resultado que se obtuvo (relacionado a los dígitos en la segunda posición), fue que con la misma metodología de tokenización cl100k y el test KS, se llegó a que, al igual que en la posición 1, la distribución empírica muestra una forma visualmente similar a la Ley de Benford, pero el test KS rechaza H_0 ($D = 0.0108$), indicando que el ajuste no es suficiente para confirmar estadísticamente el seguimiento de dicha ley, como se muestra en la siguiente figura.

Figura 2

KS y Benford para posición 2 con contraseñas tokenizadas



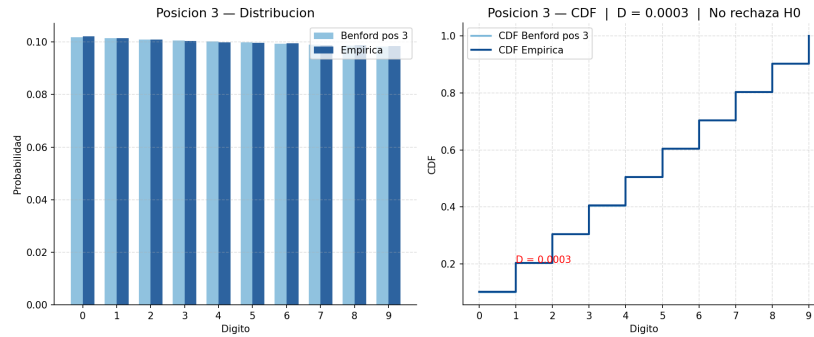
Nota. Pruebas KS aplicada para rechazar hipótesis nula en la posición 2.

La diferencia con la posición 1 es que el estadístico D es mucho menor, lo que sugiere un mejor ajuste relativo, aunque aún insuficiente. Este resultado consolida la hipótesis de que las primeras posiciones de las contraseñas son las que más se desvían del comportamiento esperado bajo Benford, lo que refuerza que las claves no son completamente aleatorias. Constituye un eslabón clave en la cadena de análisis posicional, orientando la investigación hacia la posición 3 y siguientes para buscar un ajuste formal.

Al realizar un proceso análogo a los anteriores para el tercer dígito se obtuvieron resultados diferentes, y fue que el test no rechazó H_0 ($D = 0.0003$), lo que indica que la distribución empírica de los dígitos en esta posición sigue la Ley de Benford de manera estadísticamente aceptable, como bien muestra la siguiente figura.

Figura 3

KS y Benford para posición 3 con contraseñas tokenizadas



Nota. Pruebas KS aplicada para rechazar hipótesis nula en la posición 3.

Este es el primer punto de la cadena posicional en el que se confirma formalmente el ajuste a Benford, marcando una ruptura con el comportamiento de las posiciones 1 y 2. El hallazgo es significativo porque demuestra que no basta con la similitud visual para afirmar que una distribución sigue Benford; es imprescindible validarlo con pruebas formales como el test KS. En consonancia con Caputi (2019) y Chandy et al. (2025), este resultado sienta la base para verificar si las posiciones 4 en adelante mantienen el mismo patrón, avanzando hacia una caracterización más completa de la aleatoriedad de las contraseñas.

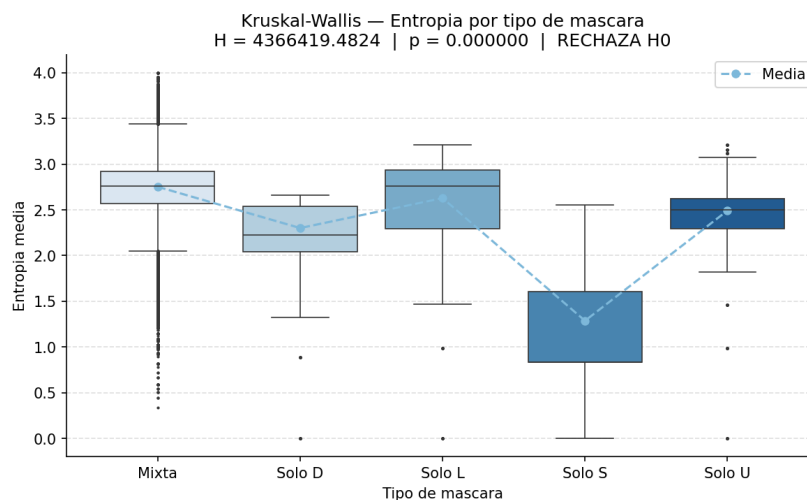
Similar al caso anterior, el análisis de la cuarta posición de las contraseñas tokenizadas con cl100k confirma, nuevamente, que el test KS no rechaza H_0 ($D = 0.0003$), validando que la distribución de dígitos en esta posición se ajusta formalmente a la Ley de Benford.

Este resultado es consistente con el hallazgo de la posición 3 y forma parte de un patrón más amplio: se determinó que a partir de la posición 3 en adelante, todas las posiciones siguen Benford de forma confirmada por KS, lo cual resulta inesperado dado que las posiciones 1 y 2 no lograron pasar el test. Esto revela que la naturaleza de los dígitos en posiciones iniciales es cuantitativamente diferente a la de las posiciones intermedias y finales, y que no basta con la similitud visual para afirmar el seguimiento de una distribución.

Luego, para el siguiente resultado se hizo uso de la prueba de Kruskal-Wallis. De acuerdo a Childs, Hindle y Warren (2021). Gracias a esta prueba se puede ver si existen diferencias significativas entre las distribuciones de varias muestras independientes. Usando lo anterior junto con el concepto

de entropía, fue que se compararon las distribuciones de entropía de contraseñas clasificadas según el tipo de máscara: mixta, solo dígitos, solo letras, solo caracteres especiales y solo mayúsculas. El test rechazó H_0 con alta significancia ($H = 4,366,419,48, p \approx 0$), evidenciando que los cinco tipos de máscara producen distribuciones de entropía completamente distintas. El siguiente gráfico permite visualizar esto último.

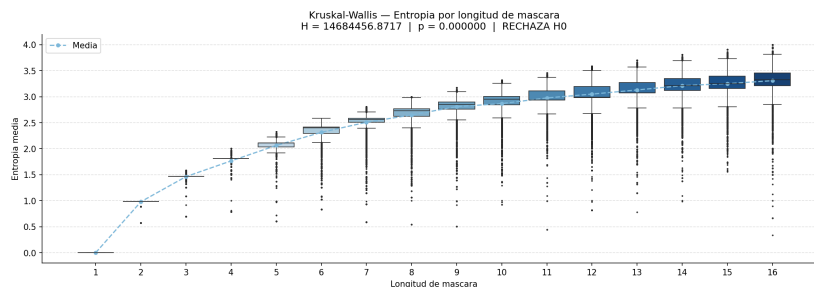
Figura 4
Prueba Kruskal-Wallis bajo tipo de máscara



Nota. Pruebas KW el tipo de máscara: mixta, solo dígitos, solo letras, solo caracteres especiales y solo mayúsculas.

Las contraseñas mixtas presentan la entropía más alta, mientras que las compuestas exclusivamente por caracteres especiales muestran los valores más bajos. Este agrupamiento es descriptivo y no inferencial, pues la variable de agrupación coincide con la variable de respuesta. Para complementar lo anterior, se hizo lo mismo pero únicamente con la longitud de la máscara. Los resultados de esto último fue que el test rechazó la hipótesis nula ($H = 14,084,456,87, p \approx 0$), confirmando que existen diferencias estadísticamente significativas entre grupos, como se muestra en el siguiente gráfico.

Figura 5
Prueba Kruskal-Wallis por longitud de la máscara



Nota. Pruebas KW aplicada por la longitud de la máscara únicamente.

Visualmente, se aprecia una tendencia creciente y clara: a mayor longitud de la contraseña, mayor es la entropía media esperada, resultado intuitivo pero que era necesario comprobar formalmente. Esto refuerza la relación entre longitud y complejidad planteada por Reaz (2024), quien asocia la entropía a la dificultad de predicción de una contraseña. No obstante, este resultado no determina qué tan aleatorias son las contraseñas ni cuáles son seguras en términos absolutos; únicamente establece que la longitud es un predictor significativo de la entropía, lo que orienta los análisis inferenciales siguientes sobre aleatoriedad real.

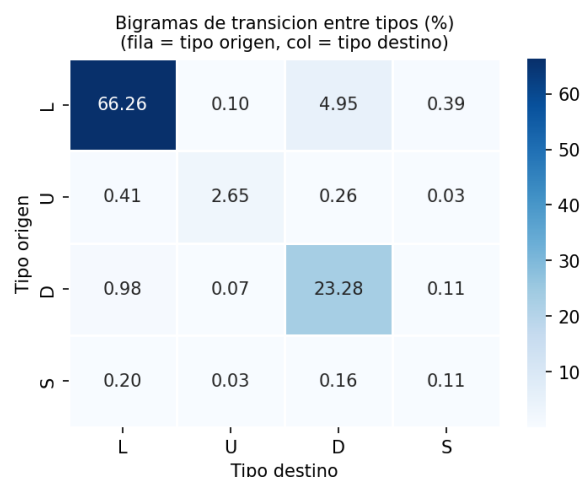
Con el fin de complementar el proyecto mediante un análisis separado de lo narrado anteriormente, se realizó un análisis descriptivo de la distribución empírica de los dígitos (0–9) en las primeras seis posiciones de las contraseñas del dataset RockYou. Se observó que la posición 1 presenta una distribución notablemente sesgada, donde los dígitos más bajos aparecen con mayor frecuencia, lo cual es compatible con la Ley de Benford; la posición 2 también muestra variación, aunque menor. A partir de la posición 3, la distribución se vuelve prácticamente uniforme: todos los dígitos tienen probabilidades de aparición muy similares, independientemente de cuál se elija.

Esto sugiere que la primera posición es la más informativa para inferir patrones de creación de contraseñas, mientras que las posiciones posteriores son más predecibles en términos de uniformidad. El resultado no mide aleatoriedad directamente ni indica qué dígitos se usan en mayor volumen, pero construye una base empírica para contrastar con la Ley de Benford (Caputi, 2019) en análisis futuros.

Por último, se construyó una matriz de biogramas para analizar las probabilidades de transición entre tipos de caracteres (letras, dígitos, mayúsculas y caracteres especiales) en las contraseñas del dataset RockYou. Los resultados muestran que la transición de letra a letra es, con diferencia, la más frecuente (66.26%), seguida de dígito a dígito (23.28%), lo que evidencia un comportamiento ordenado en la construcción de contraseñas, como se puede ver en el siguiente gráfico.

Figura 6

Matriz de biogramas de probabilidades según tipo de caracteres



Nota. Matriz de biogramas para analizar las probabilidades de transición entre tipos de caracteres (letras, dígitos, mayúsculas y caracteres especiales).

Esto permitió observar que las transiciones entre tipos distintos, como de carácter especial a otro carácter especial, son prácticamente inexistentes. Este patrón de orden se asocia al concepto de entropía planteado por Reaz (2024), donde la tendencia a permanecer dentro del mismo tipo de carácter refleja baja aleatoriedad entre tipos. Sin embargo, este resultado no describe la distribución general de contraseñas ni sus longitudes, sino únicamente el orden secuencial de sus caracteres, lo cual sienta una base para modelar mejor la entropía en pasos analíticos posteriores.

CONCLUSIONES

En primer lugar, la investigación demostró de forma contundente que las contraseñas de Rock-You no se eligen al azar, sino que siguen patrones estructurales. Esto se confirmó con la prueba de Kruskal-Wallis, que evidenció estadísticamente cómo la longitud y la máscara determinan de manera directa la entropía de Shannon, lo cual calza perfectamente con la matriz de bigramas que mostró un orden sistemático en las transiciones de caracteres. En segundo lugar, al analizar la Ley de Benford sobre la suma de los vectores de tokenización cl100k, el test de Kolmogorov-Smirnov reveló una conexión interesante, ya que la hipótesis nula se rechazó en las posiciones 1 y 2 por la alta frecuencia de los tokens iniciales, pero empezó a ajustarse a la Ley de Benford para la n -ésima posición a partir de la tercera componente, demostrando que el sesgo inicial se va diluyendo conforme se avanza en el vector. Finalmente, el bigrama de transiciones reveló que el comportamiento futuro de la contraseña está muy acotado con respecto al pasado ya transcurrido, lo que presenta una vulnerabilidad ante ataques informáticos sectorizados.

Por un lado, una limitación metodológica importante fue el intento inicial de aplicar Benford directamente sobre los dígitos numéricos de las contraseñas, un enfoque que fracasó debido a que los datos estaban sumamente sesgados por el uso de fechas, las longitudes acotadas y los hábitos de los usuarios, lo que distorsionaba las frecuencias teóricas y nos obligó a replantear todo hacia la suma tokenizada. También cabe recalcar que el proyecto estuvo condicionado por la falta total de metadatos de usuario en el archivo de RockYou, lo que impidió hacer un análisis contextual o demográfico de estos patrones, además de que los resultados quedaron amarrados únicamente a las reglas del tokenizador cl100k, dejando abierta la duda de si la convergencia que tiró el test KS es una propiedad general de las sumas vectoriales o si depende puramente de este esquema de codificación.

AGRADECIMIENTOS

Extendemos un profundo agradecimiento al profesor Maikol Solís en su acompañamiento constante durante la realización de la investigación, además de sus correcciones y orientación. También, se le agradece al asistente Jeikel Navarro por sus correcciones.

BIBLIOGRAFÍA

- Caputi, M. (2019). Ley de Benford. *Publicaciones Matemáticas del Uruguay*, 17. https://es.wikipedia.org/wiki/Ley_de_Benford
- Chandola, V., Banerjee, A., & Kumar, V. (2009). Anomaly Detection: A Survey. *ACM Computing Surveys*, 41(3), 1-58. <https://dl.acm.org/doi/10.1145/1541880.1541882>
- Chandy, M., Schifano, E., Yan, J., & Zhang, X. (2025). Nonparametric Block Bootstrap Kolmogorov-Smirnov Goodness-of-Fit Test. *arXiv preprint*. <https://arxiv.org/pdf/2511.05733.pdf>
- Childs, D. (n.d.). Non-parametric tests.
- Nigrini, M. J. (2012). *Benford's Law: Applications for Forensic Accounting, Auditing, and Fraud Detection*. John Wiley & Sons. <https://onlinelibrary.wiley.com/doi/book/10.1002/9781119203094>
- Reaz, K., & Wunder, G. (2024). Expectation Entropy as a Password Strength Metric. <https://arxiv.org/html/2404.16853v1>